

Resumen

Se ha llevado a cabo un análisis forense en el servidor Debian comprometido para identificar el vector de entrada y el alcance del ataque. Se confirmó un compromiso total del sistema tras detectar un acceso no autorizado a la cuenta de superusuario (root). El incidente fue posible debido a configuraciones de seguridad débiles en los servicios SSH, FTP y Apache, así como permisos de archivos incorrectos que expusieron credenciales críticas.

Paso 1: Evidencia Forense

Antes de arreglar nada, primero hay que hacer una copia de la maquina y a partir de ello manipular la copia para no alterar las pruebas. Despues hay que documentar las vulnerabilidades.

1. Historial de Comandos:

- **Comando:** history

```
40 sudo apt update && sudo apt upgrade -y
41 sudo apt install apache2 -y
42 sudo systemctl enable apache2
43 sudo systemctl start apache2
44 sudo systemctl status apache2
45 sudo apt install mysql-server php php-mysqli -y
46 sudo apt install mariadb-server -y
47 sudo systemctl start maria-db
48 sudo apt install mariadb-server
49 sudo systemctl start mariadb-server
50 sudo systemctl start mariadb
51 sudo systemctl enable mariadb
52 sudo mysql_secure_installation
53 sudo mysql -u root -p
54 cd /tmp
55 curl -O https://wordpress.org/latest.tar.gz
56 sudo apt install curl
57 curl -O https://wordpress.org/latest.tar.gz
58 tar xzvf latest.tar.gz
59 sudo cp -a /tmp/wordpress/. /var/www/html/
60 sudo chown -R www-data:www-data /var/www/html/
61 sudo chmod -R 755 /var/www/html/
62 cd /var/www/html/
63 sudo mv wp-config-sample.php wp-config.php
64 sudo nano wp-config.php
65 ip a
66 sudo systemctl restart apache2
67 sudo systemctl status apache2
68 sudo apt install php libapache2-mod-php php-mysqli php-gd php-xml php-mbstring php-curl -y
69 cd ..
70 sudo nano /etc/apache2/sites-available/000-default.conf
71 sudo systemctl restart apache2
72 sudo nano /var/www/html/info.php
73 ls /var/www/html
74 sudo apt install openssh-server -y
75 sudo systemctl start ssh
76 sudo systemctl enable ssh
77 sudo systemctl status ssh
78 sudo systemctl start apache2
79 history
```

```

debian@debian:~$ history
1  sudo systemctl stop speech-dispatcher
2  sudo usermood -aG root debian
3  pwd
4  sudo usermood -aG sudo debian
5  whoami
6  sudo visudo
7  su
8  sudo imod speakup
9  sudo immod speakup
10 sudo immod speakup_soft
11 sudo apt-get remove speakup
12 sudo apt-get remove speakup_soft
13 sudo ls /etc
14 sudo ls /etc/modprobe.d/
15 sudo nano /etc/modprobe.d/blacklist-speakup.conf
16 sudo nano /etc/default/grub
17 sudo update-grub
18 sudo reboot
19 dpkg -l | grep -i speech
20 sudo apt-get remove speech
21 dpkg -l | grep -i voice
22 dpkg -l | grep -i espeak
23 sudo apt-get remove espeak
24 sudo apt-get remove espeakup
25 sudo apt-get remove libespeak
26 sudo nano /etc/modprobe.d/blacklist-speakup.conf
27 dpkg -l | grep -i festival
28 dpkg -l | grep -i espeakup
29 sudo apt-get remove espeakup
30 sudo systemctl disable espeakup
31 sv-inst
32 sudo systemd-sysv-install disable espeakup
33 sudo /lib/systemd/systemd-sysv-install disable espeakup
34 sudo service espeakup stop
35 sudo systemctl status espeakup
36 sudo apt-get install git
37 git --version
38 pwd
39 ls

```

No se ven evidencias clara de ataque.

Comando: who

```

File Edit View Search Terminal Help
debian@debian:~$ who
debian  tty7          2026-01-09 10:09 (:0)
debian@debian:~$

```

No hay atacantes activos dentro del sistema.

Comando: last

```

File Edit View Search Terminal Help
debian@debian:~$ last
debian  tty7          :0          Fri Jan 9 10:09 still logged in
reboot  system boot  6.1.0-25-amd64 Fri Jan 9 10:09 still running
debian  tty7          :0          Tue Oct 8 17:28 - crash (457+17:40)
reboot  system boot  6.1.0-25-amd64 Tue Oct 8 17:28 still running
debian  tty7          :0          Tue Oct 8 16:48 - crash (00:40)
reboot  system boot  6.1.0-25-amd64 Tue Oct 8 16:48 still running
debian  tty7          :0          Tue Oct 8 16:44 - crash (00:03)
reboot  system boot  6.1.0-25-amd64 Tue Oct 8 16:43 still running
debian  tty7          :0          Mon Sep 30 15:13 - crash (8+01:29)
reboot  system boot  6.1.0-25-amd64 Mon Sep 30 15:09 still running
debian  tty7          :0          Mon Sep 30 09:49 - 12:27 (02:38)
reboot  system boot  6.1.0-23-amd64 Mon Sep 30 09:48 - 12:28 (02:39)
debian  tty7          :0          Sat Sep 28 16:40 - crash (1+17:08)
reboot  system boot  6.1.0-23-amd64 Sat Sep 28 16:39 - 12:28 (1+19:48)
debian  tty7          :0          Wed Jul 31 16:45 - 18:18 (01:33)
reboot  system boot  6.1.0-23-amd64 Wed Jul 31 16:45 - 18:19 (01:34)
debian  tty7          :0          Wed Jul 31 16:04 - 16:44 (00:39)
reboot  system boot  6.1.0-23-amd64 Wed Jul 31 16:04 - 16:44 (00:40)
debian  tty7          :0          Wed Jul 31 15:57 - 15:59 (00:01)
reboot  system boot  6.1.0-23-amd64 Wed Jul 31 15:56 - 15:59 (00:02)

wtmp begins Wed Jul 31 15:56:58 2024

```

Hay varios crash en periodos muy cortos de tiempo. El día que se conecto el 192.168.0.134, esto sugiere que el atacante pudo haber causado inestabilidad.

Puertos y Servicios Expuestos:

- **Comando:** sudo netstat -antp.

```
tcp6      0      0 :::80                :::*                LISTEN      -
tcp6      0      0 :::22                :::*                LISTEN      -
tcp6      0      0 :::21                :::*                LISTEN      -
debian@debian:~$
```

- Puerto 21 (FTP), 22 (SSH) y 80 (HTTP) en estado LISTEN.

Se ve que estos puertos están en modo escucha a conexiones externa. No es un riesgo que estén expuestos pero si que no tengan el nivel de seguridad necesario.

Puerto 22

He utilizado el comando: **sudo journalctl -u ssh | grep "Failed password"** para ver si hay algún intento de acceder.

Después utilizo el comando: **sudo journalctl -u ssh | grep "accepted"**

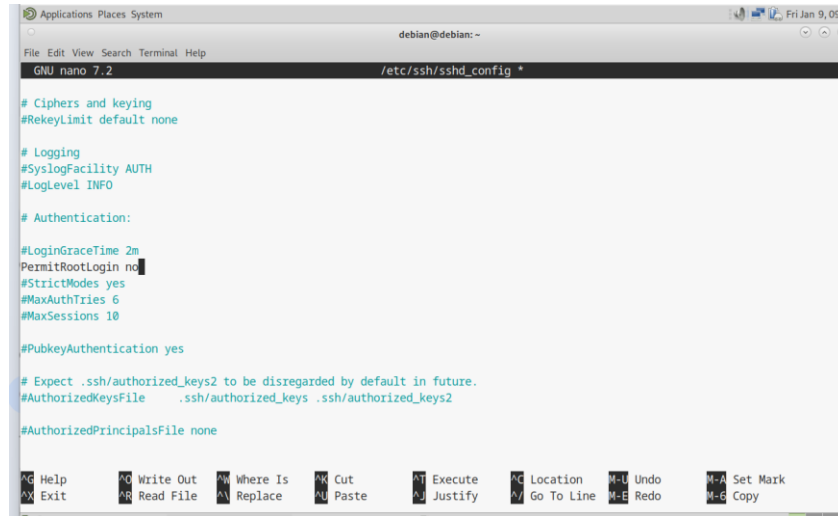
```
debian@debian:~$ sudo journalctl -u ssh | grep "Failed password"
debian@debian:~$ sudo journalctl -u ssh | grep "Accepted"
Oct 08 17:40:59 debian sshd[1650]: Accepted password for root from 192.168.0.134 port 45623 ssh2
debian@debian:~$
```

Y como se aprecia en la imagen se ve que consiguieron conectarse desde el 192.168.0.134 por el puerto 45623 ssh.

EL atacante aprovecho que la configuración de SSH que permite el acceso directo a la cuenta de superusuario.

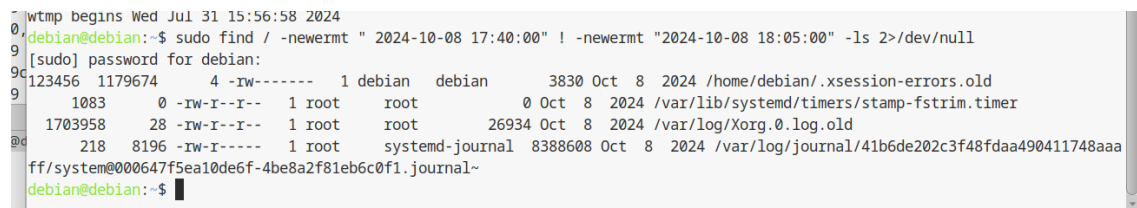
Esto habría que solucionarlo y cambiar la configuración para no volver a tener ese problema. Y cambiar el PermitRootLogin Yes a No.

Solucion: desde sudo nano `/etc/ssh/sshd_config` para evitar que el ataque escale.



```
debian@debian: ~  
File Edit View Search Terminal Help  
GNU nano 7.2 /etc/ssh/sshd_config *  
  
# Ciphers and keying  
#RekeyLimit default none  
  
# Logging  
#SyslogFacility AUTH  
#LogLevel INFO  
  
# Authentication:  
  
#LoginGraceTime 2m  
PermitRootLogin no  
#StrictModes yes  
#MaxAuthTries 6  
#MaxSessions 10  
  
#PubkeyAuthentication yes  
  
# Expect .ssh/authorized_keys2 to be disregarded by default in future.  
#AuthorizedKeysFile .ssh/authorized_keys .ssh/authorized_keys2  
  
#AuthorizedPrincipalsFile none  
  
Help Write Out Where Is Cut Execute Location Undo Set Mark  
Exit Read File Replace Paste Justify Go To Line Redo Copy
```

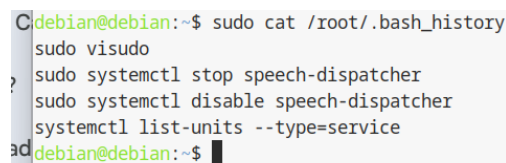
Al detectar que a las 15:40 el usuario accedió como root, hice una búsqueda, en la cual quería observar si había alguna modificación en esa franja horaria



```
wtm begins Wed Jul 31 15:56:58 2024  
debian@debian:~$ sudo find / -newermt " 2024-10-08 17:40:00" ! -newermt "2024-10-08 18:05:00" -ls 2>/dev/null  
[sudo] password for debian:  
123456 1179674 4 -rw----- 1 debian debian 3830 Oct 8 2024 /home/debian/.xsession-errors.old  
1083 0 -rw-r--r-- 1 root root 0 Oct 8 2024 /var/lib/systemd/timers/stamp-fstrim.timer  
1703958 28 -rw-r--r-- 1 root root 26934 Oct 8 2024 /var/log/Xorg.0.log.old  
218 8196 -rw-r----- 1 root systemd-journal 8388608 Oct 8 2024 /var/log/journal/41b6de202c3f48fdaa490411748aaa  
ff/system@000647f5ea10de6f-4be8a2f81eb6c0f1.journal~  
debian@debian:~$
```

`sudo find / -newermt "2024-10-08 17:40:00" ! -newermt "2024-10-08 18:05:00" -ls 2>/dev/null`

Este comando busca archivos modificados después de las 17:40 y antes de las 18:05 del 8 de octubre.



```
debian@debian:~$ sudo cat /root/.bash_history  
sudo visudo  
sudo systemctl stop speech-dispatcher  
sudo systemctl disable speech-dispatcher  
systemctl list-units --type=service  
debian@debian:~$
```

Tras ejecutar un análisis de integridad de archivos en el rango temporal del incidente (17:40 - 18:05), observe que no hubo creación de artefactos maliciosos en el sistema de archivos.

Puerto 21

El puerto 21 tiene el servicio vsftpd 3.0.3 y tiene habilitado el acceso anonimo, lo que permite transferencia de archivo sin credenciales.

```
PORT STATE SERVICE VERSION
21/tcp open  ftp      vsftpd 3.0.3
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ftp-syst:
|_STAT:
|_FTP server status:
|_Connected to ::ffff:192.168.1.38
|_Logged in as ftp
|_TYPE: ASCII
|_No session bandwidth limit
|_Session timeout in seconds is 300
|_Control connection is plain text
|_Data connections will be plain text
|_At session startup, client count was 2
|_vsFTPD 3.0.3 - secure, fast, stable
|_End of status
```

Solución: Editar el archivo:

```
sudo nano /etc/vsftpd.conf
```

```
anonymous_enable=NO
```

Reiniciar: `sudo systemctl restart vsftpd`

```
#
# Allow anonymous FTP? (Disabled by default).
anonymous_enable=NO
#
# Uncomment this to allow local users to log in.
```

Puerto 80

Tiene el listado de directorio activo y exposición de credenciales.

```
80/tcp open  http      Apache httpd 2.4.62 ((Debian))
|_http-robots.txt: 1 disallowed entry
|_/_wp-admin/
|_http-server-header: Apache/2.4.62 (Debian)
|_http-title: Apache2 Debian Default Page: It works
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: bridge|VoIP adapter|general purpose
Running (JUST GUESSING): Oracle Virtualbox (98%), Slirp (98%), AT&T embedded (95%), QEMU (94%)
OS CPE: cpe:/o:oracle:virtualbox cpe:/a:danny_gasparovski:slirp cpe:/a:qemu:qemu
Aggressive OS guesses: Oracle Virtualbox Slirp NAT bridge (98%), AT&T BGW210 voice gateway (95%), QEMU user mode network gateway (94%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

TRACEROUTE (using port 80/tcp)
HOP RTT ADDRESS
1 0.16 ms 192.168.1.55
```

Solucion: Desactivar indexes en apache y aplicar el `chmod 600` a `wp-config.php`

Linea de tiempo.

```
13651 Oct 08 17:40:59 debian sshd[1650]: Accepted password for root from 192.168.0.134 port 45623 ssh2
13652 Oct 08 17:40:59 debian sshd[1650]: pam_unix(sshd:session): session opened for user root(uid=0) by (uid=0)
13653 Oct 08 17:40:59 debian systemd[1]: Created slice user-0.slice - User Slice of UID 0.
13654 Oct 08 17:40:59 debian systemd[1]: Starting user-runtime-dir@0.service - User Runtime Directory /run/user/0...
13655 Oct 08 17:40:59 debian systemd-logind[488]: New session 6 of user root.
13656 Oct 08 17:40:59 debian (systemd)[1653]: pam_unix(systemd-user:session): session opened for user root(uid=0) by (uid=0)
13657 Oct 08 17:40:59 debian systemd[1]: Finished user-runtime-dir@0.service - User Runtime Directory /run/user/0.
13658 Oct 08 17:40:59 debian systemd[1]: Starting user@0.service - User Manager for UID 0...
13659 Oct 08 17:40:59 debian systemd[1653]: Queued start job for default target default.target.
13660 Oct 08 17:40:59 debian systemd[1653]: Created slice app.slice - User Application Slice.
13661 Oct 08 17:40:59 debian systemd[1653]: Created slice session.slice - User Core Session Slice.
13662 Oct 08 17:40:59 debian systemd[1653]: Reached target paths.target - Paths.
13663 Oct 08 17:40:59 debian systemd[1653]: Reached target timers.target - Timers.
13664 Oct 08 17:40:59 debian systemd[1653]: Starting dbus.socket - D-Bus User Message Bus Socket...
13665 Oct 08 17:40:59 debian systemd[1653]: Listening on dirnmgd.socket - GnuPG network certificate management daemon.
13666 Oct 08 17:40:59 debian systemd[1653]: Listening on gcr-ssh-agent.socket - GCR ssh-agent wrapper.
13667 Oct 08 17:40:59 debian systemd[1653]: Listening on gnome-keyring-daemon.socket - GNOME Keyring daemon.
13668 Oct 08 17:40:59 debian systemd[1653]: Listening on gpg-agent-browser.socket - GnuPG cryptographic agent and passphrase
cache (access for web browsers).
13669 Oct 08 17:40:59 debian systemd[1653]: Listening on gpg-agent-extra.socket - GnuPG cryptographic agent and passphrase
cache (restricted).
13670 Oct 08 17:40:59 debian systemd[1653]: Listening on gpg-agent-ssh.socket - GnuPG cryptographic agent (ssh-agent
emulation).
13671 Oct 08 17:40:59 debian systemd[1653]: Listening on gpg-agent.socket - GnuPG cryptographic agent and passphrase cache.
13672 Oct 08 17:40:59 debian systemd[1653]: pulseaudio.socket - Sound System was skipped because of an unmet condition check
(ConditionUser=!root).
13673 Oct 08 17:40:59 debian systemd[1653]: Listening on dbus.socket - D-Bus User Message Bus Socket.
13674 Oct 08 17:40:59 debian systemd[1653]: Reached target sockets.target - Sockets.
13675 Oct 08 17:40:59 debian systemd[1653]: Reached target basic.target - Basic System.
13676 Oct 08 17:40:59 debian systemd[1]: Started user@0.service - User Manager for UID 0.
13677 Oct 08 17:40:59 debian systemd[1]: Started session-6.scope - Session 6 of User root.
13678 Oct 08 17:40:59 debian systemd[1653]: pulseaudio.service - Sound Service was skipped because of an unmet condition check
(ConditionUser=!root).
13679 Oct 08 17:40:59 debian systemd[1653]: Reached target default.target - Main User Target.
13680 Oct 08 17:40:59 debian systemd[1653]: Startup finished in 132ms.
13681 Oct 08 17:40:59 debian sshd[1650]: pam_env(sshd:session): deprecated reading of user environment enabled
13682 Oct 08 17:43:59 debian systemd[1]: Starting systemd-tmpfiles-clean.service - Cleanup of Temporary Directories...
13683 Oct 08 17:44:00 debian systemd[1]: systemd-tmpfiles-clean.service: Deactivated successfully.
13684 Oct 08 17:44:00 debian systemd[1]: Finished systemd-tmpfiles-clean.service - Cleanup of Temporary Directories.
13685 Oct 08 17:44:00 debian systemd[1]: run-credentials-systemd\x2dtmpfiles\x2dclean.service.mount: Deactivated successfully.
13686 Oct 08 17:57:51 debian NetworkManager[498]: <info> [1728424671.0885] dhcp6 (enp0s3): state changed new lease,
address=2800:810:458:173:8879:c1b2:f8ba:ceb5
13687 Oct 08 17:58:38 debian NetworkManager[498]: <info> [1728424718.3542] dhcp4 (enp0s3): state changed new lease,
address=192.168.0.137
13688 Oct 08 17:50:59 debian systemd[1]: Starting fdtvm.service - Discard unused blocks on filesystems from /etc/fstab...
```

Medidad de limpieza final

Actualizacion de seguridad: Se ejecuta `sudo apt update` && `sudo apt upgrade -y`

Para parchear versiones vulnerables de los servicios analizados y las souciones dadas anteriormente.